

HTTP edge (.htaccess + config)

CSP (pinned jsDelivr)
nosniff
DENY framing
same-origin referrer
direct-file deny



Session layer (auth.php)

regenerated IDs
24h idle expiry
remember-me rotate (SHA-256, 30d)
revoke on logout/password



Request guards (api.php)

requireApiAuth (401)
requireApiCsrft (403)
requireApiMethod
requireOwnedCategory



Input + data (validation + repositories)

two-layer validation
user-scoped prepared SQL
escaping
allowlists



Secrets (bcrypt + responses)

password_hash + rehash
generic errors
no SQL/paths/traces